

Aula 1

Segurança da Informação

Prof. Patrick Landal Athayde

Visão geral da segurança da informação

Visão geral da segurança da informação

- A segurança, embora amplamente debatida e dotada de múltiplos significados, adquire contornos específicos quando relacionada ao contexto informacional
- No século XXI, a informação consolidou-se como um ativo estratégico de elevado valor para as organizações, influenciando diretamente os processos decisórios e contribuindo para a geração de experiências diferenciadas aos usuários

Visão geral da segurança da informação

- Fontes (2006, p. 2): "A informação é um recurso que tem valor para a organização e deve ser bem gerenciado e utilizado [...] é necessário garantir que ela esteja sendo disponibilizada apenas para as pessoas que precisam dela para o desempenho de suas atividades profissionais"
- A informação, no contexto da segurança da informação, assume o papel de um ativo estratégico e essencial para as organizações contemporâneas

O que é informação?

- Informação é o conjunto estruturado de dados que confere significado a um determinado contexto, indivíduo ou objeto

- Desde o nascimento, cada pessoa gera e acumula informações

- RG
- CPF
- Título de eleitor
- CNH

Segurança da informação

Segurança da informação

- A segurança da informação consiste em práticas, políticas e controles que visam proteger os dados contra ameaças internas e externas, assegurando sua confidencialidade, integridade e disponibilidade

Segurança da informação

- Lyra (2017, p. 3): temos a segurança da informação diretamente relacionada com a proteção de um conjunto de informações, para preservar o valor que possuem para um indivíduo ou organização, independentemente de estarem associadas a sistemas computacionais, informações eletrônicas ou mesmo sistemas de armazenamento

- Agências padronizadoras
 - *International Organization for Standardization (ISO)*
 - *International Electrotechnical Commission (IEC)*
- Essas entidades desenvolveram uma série de normas técnicas que estruturam práticas e diretrizes globais para a proteção da informação

Segurança da informação

- O conceito de segurança da informação fundamenta-se na preservação da tríade CIA (confidencialidade, integridade e disponibilidade), princípios essenciais para a sustentabilidade organizacional no ambiente digital atual (Whitman; Mattord, 2018)

Aspectos da segurança da informação

Confidencialidade

- “A confidencialidade, pilar essencial da segurança da informação, consiste na garantia de que dados sensíveis sejam acessados exclusivamente por usuários ou entidades autorizadas, conforme políticas de controle de acesso, mitigando riscos de exposição indevida” (ISO/IEC 27002, 2022, p. 12)

Confidencialidade

- Whitman e Mattord (2021) destacam que essa propriedade protege a integridade operacional e assegura conformidade com regulamentações como a Lei Geral de Proteção de Dados (LGPD) e o Regulamento Geral sobre a Proteção de Dados (GDPR). Segundo a ISO/IEC 27002 (2022), a confidencialidade está diretamente vinculada à gestão criteriosa de permissões, alinhada ao princípio do “need-to-know” descrito por Stallings (2017), que restringe o acesso com base em critérios funcionais e hierárquicos

Integridade

- A integridade da informação, conforme a ISO/IEC 27002 (2022, Seção 8.1.2), garante a autenticidade, precisão e consistência dos dados ao longo de seu ciclo de vida, protegendo-os contra alterações não autorizadas
- Para Whitman e Mattord (2021), qualquer desvio, seja por erro, falha ou ação maliciosa, compromete decisões estratégicas e a conformidade com normas regulatórias

Disponibilidade

- A disponibilidade, conforme definido pela ISO/IEC 27002 (2022, Seção 8.1.3), refere-se à garantia de que informações e sistemas estejam acessíveis e operacionais sempre que necessários, exigindo não apenas a presença dos dados, mas também resiliência tecnológica, processos de recuperação eficientes e prevenção de interrupções

Autenticidade

- A autenticidade, conforme definido pela ISO/IEC 27002 (2022, Seção 8.2.1), é uma propriedade essencial da segurança da informação, que assegura a veracidade e a origem legítima de dados, transações e identidades, por meio de mecanismos técnicos e organizacionais que previnem falsificações e repúdios

Responsabilização

- A responsabilização é um princípio fundamental da segurança da informação, pois garante que ações realizadas por usuários, sistemas ou processos possam ser inequivocamente atribuídas a seus autores, assegurando irretratabilidade e permitindo a adoção de medidas corretivas, legais ou preventivas



Figura 1: Principais conceitos da Segurança da informação.

Os desafios da segurança de informação

Desafios da segurança da informação

- A segurança da informação, dos computadores e redes configura-se como um campo complexo e multifacetado, influenciado por aspectos técnicos, organizacionais e humanos, cuja efetividade exige compreensão aprofundada das ameaças emergentes e estruturas sofisticadas de defesa (Stallings, 2017)

Desafios da segurança da informação

- A localização física e lógica dos controles, conforme a arquitetura TCP/IP, é crucial para sua eficiência (Rossi Filho, 2006)
- A gestão adequada de informações secretas, especialmente chaves criptográficas, cuja proteção é vital para a integridade do sistema (Stallings, 2017)

Desafios da segurança da informação

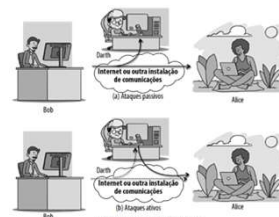
- A segurança é caracterizada como uma "batalha de inteligência" entre atacantes, que buscam uma única falha, e defensores, que precisam garantir a ausência de vulnerabilidades em todos os pontos (Pfleeger, 2015, p. 34)

- "Ameaça consiste de uma chance de violação da segurança que existe quando há uma circunstância, capacidade, ação ou evento que poderia quebrar a segurança e causar danos. Ou seja, uma ameaça é um possível perigo a explorar uma vulnerabilidade. Um ataque à segurança do sistema, derivado de uma ameaça inteligente; ou seja, um ato inteligente que é uma tentativa deliberada (especialmente no sentido de um método ou técnica) de fugir dos serviços de segurança e violar a política de segurança de um sistema" (Stallings, 2017, p. 10)

Ataques a segurança

- Os ataques à segurança da informação, de modo geral, podem ser classificados em ataques passivos e ativos
- Passivos:** são aqueles que tentam “descobrir ou utilizar informações do sistema, mas não afetam seus recursos” (Stallings, 2015, p. 11)
- Ativos:** podem ser definidos como aqueles que “tentam alterar recursos do sistema ou afetar sua operação” (Stallings, 2015, p. 11)

Ataques a segurança



Crédito: Jefferson Schneider
Figura 2: Ataques passivos e ativos.
 Fonte: Stallings (2015)

Segurança e o ciclo de vida da informação

Segurança e o ciclo de vida da informação

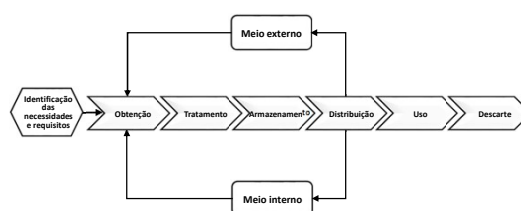


Figura 3: Ciclo de vida da informação.
 Fonte: Lyra (2017)

Identificação das necessidades e dos requisitos

- A identificação das necessidades informacionais de grupos ou processos organizacionais constitui etapa essencial para a produção de serviços e produtos informacionais eficazes. Esse mapeamento favorece decisões mais qualificadas e orientadas aos objetivos institucionais

Obtenção

- Nesta etapa, são instituídos os procedimentos para a captação de informações, sejam elas provenientes de fontes externas ou de processos internos. No caso de dados externos, destaca-se a necessidade de garantir sua autenticidade, completude e conformidade

Tratamento

- O tratamento da informação envolve etapas como organização, formatação e análise, com o objetivo de torná-la mais acessível e funcional. Nesse processo, é fundamental preservar sua integridade e confidencialidade

Uso

- Nesta etapa, a informação é aplicada de maneira a agregar valor à organização. Os princípios de disponibilidade, integridade e confidencialidade devem ser rigorosamente observados, a fim de garantir o uso seguro e eficaz dos ativos informacionais

Armazenamento

- O armazenamento da informação tem por finalidade garantir sua preservação para usos futuros, exigindo cuidados com a integridade, disponibilidade e, em casos sensíveis, com a confidencialidade dos dados

Descarte

- O descarte de informações obsoletas deve seguir procedimentos formais que observem normas legais e diretrizes internas, contribuindo para a eficiência da gestão informacional. Esse processo exige medidas rigorosas de segurança, sobretudo quanto à proteção da confidencialidade

- A gestão eficaz da informação exige mais do que o controle de fluxos de dados: requer práticas que assegurem sua qualidade, disponibilidade, integridade e confidencialidade ao longo de todo o ciclo de vida organizacional
- Por tratar-se de um ativo estratégico, a informação demanda mecanismos de proteção alinhados às normativas de segurança, que orientem políticas e controles capazes de mitigar riscos, garantir conformidade e fortalecer a governança informacional

Referências

- **ALMEIDA, I. M.; ROSSETTI, J. P.** Segurança da informação: uma abordagem gerencial. São Paulo: Atlas, 2015.
- **ANDERSON, R.** Security engineering: a guide to building dependable distributed systems. 3. ed. Indianapolis: Wiley, 2020.
- **FERNANDEZ, E. B.** Security patterns in practice: designing secure architectures using software patterns. 1. ed. Nova York: Wiley, 2013.

- **FONTES, E.** Segurança da informação: o usuário faz a diferença. São Paulo: Saraiva, 2006.
- **HERRMANN, D. S.** Complete guide to security and privacy metrics. Boca Raton: Auerbach Publications, 2019.
- **INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. ISO/IEC 27002:2022:** Information security, cybersecurity and privacy protection — Information security controls. Geneva: ISO, 2022.

- **INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. ISO/IEC 27001:2022 —** Information security, cybersecurity and privacy protection — Information security management systems — Requirements. Disponível em: <https://www.iso.org/standard/82875.html>. Acesso em: 25 jun. 2025.
- **WHITMAN, M. E.; MATTORD, H. J.** Principles of information security. 7. ed. Boston: Cengage Learning, 2018.